

Observ Incident — Walkthrough (AUTHOR TEMPLATE)

Observ Incident — Walkthrough

 **AUTHOR TEMPLATE — complete before submitting.** OffSec does not accept Grimoire walkthroughs that are generated, drafted, or substantially written by AI. This file provides **structure only**. Write the analysis in your own words, replacing every `[AUTHOR: ...]` prompt. Add your own screenshots of the evidence as you work through it. Delete this banner and the “Reference facts” appendix before exporting the final `walkthrough.pdf`.

- **Lab:** Observ Incident (Grimoire, defensive)
- **Difficulty:** Intermediate (defender’s perspective)
- **Flags:** 2 × `OS{...}`

1. Scenario & scope

[AUTHOR: 2–4 sentences in your own words — what alerted, which hosts, what the analyst is asked to determine. Keep it to the evidence provided.]

2. Evidence inventory

[AUTHOR: briefly describe each artifact you were given and why it matters.]

Artifact	What it tells you
<code>web01/var/log/apache2/access.log</code>	[AUTHOR]
<code>web01/var/log/observ/diag_debug.log</code>	[AUTHOR]
<code>web01/var/log/auth.log</code>	[AUTHOR]
<code>web01/home/developer/.bash_history</code>	[AUTHOR]
<code>web01/tmp/.x/netcheck.py</code>	[AUTHOR]

Artifact	What it tells you
<code>internal01/var/log/auth.log</code>	[AUTHOR]
<code>internal01/home/svc_backup/.bash_history</code>	[AUTHOR]
<code>internal01/tmp/.exfil/stage.txt</code>	[AUTHOR]

3. Initial access (web01)

[AUTHOR: identify the source IP and how the attacker reached code execution. Reference the specific log lines. Explain the command-injection parameter.]

4. Credential reuse & foothold

[AUTHOR: explain the reused credential and the SSH login as the local account.]

5. Privilege escalation on web01

[AUTHOR: explain how the attacker obtained root via the sudo health-check and the preserved PYTHONPATH, citing the recovered module and the sudo log line.]

First flag

[AUTHOR: show how you recovered `flag_web01` by base64-decoding the marker in the diagnostics debug log. Paste the command and the decoded value.]

6. Lateral movement / pivot

[AUTHOR: show the discovery of the internal host and the key, and the SSH into internal01. Cite the auth.log publickey line and the source address.]

7. Privilege escalation on internal01

[AUTHOR: explain the sudo tar GTFEBins abuse from the auth.log / bash history.]

Second flag

[AUTHOR: show how you recovered `flag_internal` from the staged exfil file.]

8. Timeline

[AUTHOR: a short chronological table of the key events with timestamps.]

9. Detections & lessons

[AUTHOR: what detections would have caught this earlier? See mitre-attack.md for mapping ideas, but write the recommendations yourself.]

Appendix — Reference facts (DELETE before submitting)

Scaffolding for the author; not student-facing. Full citations in `artifacts.zip/answer-key.md`.

- attacker_ip = 10.10.14.7
- cmdi_param = host
- reused_account = developer
- privesc_web01 = PYTHONPATH hijack (T1574.007)
- flag_web01 = OS{w3b01_rc3_d14g_c0mm4nd_1nj}
- pivot_ip = 172.20.0.3
- gtfobins_binary = tar
- flag_internal = OS{1nt3rn4l_r00t_sud0_tar_pivot}